

Reporte de evaluación de seguridad

Cliente: **britimp** · Alcance: 172.30.0.0/24 (vulnerable-lab)

Engagement: britimp-demo-2026-04-15 · Generado: 2026-04-15 15:56 UTC · Auditor: SkyVanguard / Kryon

Resumen ejecutivo

Se identificaron **6 hallazgos** en el alcance 172.30.0.0/24 (vulnerable-lab).

1 CRITICAL requieren remediación inmediata (impacto potencial: exposición de servicios, credenciales débiles, o configuración que habilita escalación).

3 HIGH deben resolverse en la ventana de remediación estándar del cliente.

Hosts afectados: 3 (target-db, target-ssh, target-web).

El detalle técnico con evidencia y pasos de remediación se presenta en las secciones siguientes. Las acciones marcadas [DRY-RUN] en el log fueron simuladas, no aplicadas.

TOTAL

6

CRITICAL

1

HIGH

3

MEDIUM

1

LOW

1

INFO

0

Índice de hallazgos

#	Severidad	CWE	Host	Regla	Descripción
1	CRITICAL	CWE-521	target-ssh	sshd-permit-root-login	SSH permite login de root con contraseña.

#	Severidad	CWE	Host	Regla	Descripción
2	HIGH	CWE-319	target-db	mysql-no-tls	MySQL sin TLS.
3	HIGH	CWE-307	target-ssh	sshd-max-auth-tries	MaxAuthTries 10 permite fuerza bruta.
4	HIGH	CWE-306	target-web	nginx-admin-open	/admin accesible sin auth.
5	MEDIUM	CWE-200	target-web	nginx-server-tokens	Header Server expone versión.
6	LOW	CWE-1004	target-web	cookie-no-httponly	Cookie sin HttpOnly/Secure.

Detalle técnico

CRITICAL SSH permite login de root con contraseña.

CWE-521 · target-ssh · rule: sshd-permit-root-login

```
PermitRootLogin yes
PasswordAuthentication yes
```

Remediación: Desactivar PermitRootLogin y requerir clave pública.

HIGH MySQL sin TLS.

CWE-319 · target-db · rule: mysql-no-tls

```
require_secure_transport no configurado
```

Remediación: Habilitar TLS.

HIGH **MaxAuthTries 10 permite fuerza bruta.**

CWE-307 · target-ssh · rule: sshd-max-auth-tries

```
MaxAuthTries 10
```

Remediación: Bajar a 3 + fail2ban.

HIGH **/admin accesible sin auth.**

CWE-306 · target-web · rule: nginx-admin-open

```
GET /admin → 200
```

Remediación: Agregar auth_basic.

MEDIUM **Header Server expone versión.**

CWE-200 · target-web · rule: nginx-server-tokens

```
Server: nginx/1.27.5
```

Remediación: server_tokens off.

LOW **Cookie sin HttpOnly/Secure.**

CWE-1004 · target-web · rule: cookie-no-httponly

```
Set-Cookie sin flags
```

Remediación: Añadir HttpOnly y Secure.